ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Ubuntu Linux (LTS) · Component type: **Host Device (HDR) - server / EWS / OWS** · Target SL = SL 3

Where to work	**Shell** (SSH/console) as an authorized least-priv user with `sudo`; config in **/etc** (`/etc/ssh/sshd_config`, `/etc/security/*`, `/etc/audit/*`); `systemctl`, `ufw`, `auditctl`. Baseline against the **CIS Ubuntu Benchmark** / **DISA Ubuntu STIG**.
Interfaces / ports	SSH **22**; only required app ports open. Disable telnet/FTP/rsh/rlogin. Management via SSH/console.
Notes	HDR (host / EWS/OWS/server). Confirm release (`lsb_release -a`) and LTS support. Most controls verified read-only via config files + `systemctl`/`auditctl` state.
How to read	Default read-only (read config + query state). Native how-to + external-tool validation + pass. Scan/exploit tools = **authorized**; write/exploit = isolated env.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 1.1	Human user I&A;	SSH: `sshd -T | grep -E "permitrootlogin|permitemptypasswords|passwordauthentication"` -> `PermitRootLogin no`, `PermitEmptyPasswords no`; local accounts in `/etc/passwd` (no UID-0 besides root; no empty `/etc/shadow` fields); LDAP/SSSD where used. **Test:** root SSH denied; no anonymous/blank-password login. **Ext. tools:** ssh-audit; Lynis; OpenSCAP (CIS/STIG).	All logon authenticates; root SSH disabled; no empty passwords.	HDR.
SR/CR 1.2	Software Process and Device Identification and Authentication	Assess per objective: Identify and authenticate all software processes and devices.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 1.3	Account management	Review `getent passwd` / `getent group sudo`; remove/disable unused & system-login accounts (`nologin`); expire stale (`chage -l`). **Ext. tools:** Lynis; OpenSCAP; `getent`	Named, least-priv accounts; no stale/shared; service accounts non-login.	
SR/CR 1.4	Identifier Management	Confirm identifiers (user and device IDs) are unique, not reused, and managed over their lifecycle.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 1.5 / 1.7	Authenticator & password strength	PAM `pam_pwquality` in `/etc/security/pwquality.conf` (minlen=14, dcredit/ucredit/ocredit/lcredit); `/etc/login.defs` PASS_MAX_DAYS/MIN/WARN; SHA-512 hashing in `/etc/shadow`. **Ext. tools:** OpenSCAP/CIS scan; config review.	Strong password policy (length/complexity/age) enforced via PAM.	
SR/CR 1.6	Wireless Access Management	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 1.8	Public Key Infrastructure (PKI) Certificates	Confirm any device/server certificates are CA-issued, valid, and revocable per PKI practice.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 1.9	Strength of Public Key Authentication	Confirm public-key / certificate authentication uses strong keys and algorithms (>=2048 RSA / ECC).	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 1.10	Authenticator Feedback	Confirm authenticators (passwords) are obscured during entry (masked) on every interface.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 1.11	Unsuccessful login attempts	`pam_faillock` in `/etc/security/faillock.conf` (deny=5, unlock_time=900, fail_interval); optionally `fail2ban` for SSH. **Test:** exceed the threshold -> account/IP locked; `faillock` shows the count. **Ext. tools:** Hydra (ISOLATED, authorized) to confirm faillock/fail2ban; `faillock` review.	Lockout after few failed attempts; brute force throttled.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 1.12	System use notification	Set `/etc/issue`, `/etc/issue.net`, and SSH `Banner /etc/issue.net` to the approved notice; confirm it shows at console/SSH login. **Ext. tools:** CIS scan; login visual check.	Approved banner displayed before login on console + SSH.	
SR/CR 1.13	Access via untrusted networks	Harden SSH (key-based, MFA via `pam_google_authenticator`/SSSD); `ufw` restrict SSH to mgmt subnets; `fail2ban`; VPN for remote. **Test:** SSH from untrusted -> blocked/needs MFA. **Ext. tools:** Nmap (22 reachability by segment); `ufw status verbose`	Remote access key/MFA-based and restricted to mgmt networks.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 2.1	Authorization enforcement	Least-privilege `sudo`: review `/etc/sudoers` + `/etc/sudoers.d/*` (`visudo -c`) for broad NOPASSWD/ALL; check critical file perms/ownership; **AppArmor** profiles enforcing. **Test:** a standard user cannot perform admin actions. **Ext. tools:** Lynis; `sudo -l` as user; `aa-status`	Least privilege enforced (sudo + AppArmor); no broad NOPASSWD.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 2.3	Use Control for Portable and Mobile Devices	Assess per objective: Enforce configurable usage restrictions for portable/mobile devices.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 2.4	Mobile Code	Assess per objective: Enforce usage restrictions for mobile code technologies.	Met per SL-3 - verify on the product and capture evidence.	completeness
HDR 2.4	Mobile Code (Host)	Assess the HDR-specific requirement per objective: Host device shall control and restrict the use of mobile code, enforcing authorization, integrity, and execution constraints.	Met per SL-3 - verify and capture evidence.	HDR completeness
SR/CR 2.5	Session lock	Shell idle timeout `TMOUT` in `/etc/profile.d/`; desktop screen-lock where GUI. Confirm effective. **Ext. tools:** Config review; manual idle test.	Idle sessions time out / lock.	
SR/CR 2.6	Remote Session Termination	Confirm remote sessions can be terminated on demand and on inactivity timeout.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 2.7	Concurrent Session Control	Confirm concurrent-session limits or monitoring for privileged/engineering access.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 2.8	Auditable events	**auditd** running with rules (`auditctl -l`, `/etc/audit/rules.d/`) for logins, sudo, identity/privilege, and critical-file changes; forward `rsyslog`/journald to the SIEM. **Test:** a sudo/login event is recorded. **Ext. tools:** OpenSCAP (audit rules); `ausearch`; SIEM check.	Security events audited (auditd) with user + time; forwarded to SIEM.	
SR/CR 2.9	Audit Storage Capacity	Confirm audit/log storage is sized and rotated and alerts before overflow (or offloads to syslog/SIEM).	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 2.10	Response to Audit Processing Failures	Confirm defined behavior on audit/log processing failure (alert; do not silently drop events).	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 2.11	Timestamps	Time sync via `chrony`/`systemd-timesyncd`: `timedatectl` / `chronyc sources` to an authenticated NTP source. **Ext. tools:** `timedatectl`; Wireshark (NTP).	Accurate synchronized time; logs use synced time.	
SR/CR 2.12	Non-repudiation	Assess per objective: Determine whether a given human user took a particular action.	Met per SL-3 - verify on the product and capture evidence.	completeness
HDR 2.13	Physical Diagnostic/Test Interfaces (Host)	Assess the HDR-specific requirement per objective: Host device shall protect against unauthorized use of physical diagnostic and test interfaces.	Met per SL-3 - verify and capture evidence.	HDR completeness

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 3.1 / 3.8	Communication & session integrity	Only encrypted services (SSH/TLS); confirm telnet/FTP/rsh removed (`ss -tlnp`); SSH strong ciphers/KEX (`sshd -T | grep -E "ciphers|kexalgorithms|macs"`). **Ext. tools:** ssh-audit; Nmap; `ss -tlnp`	Only encrypted protocols listen; strong SSH crypto; cleartext services gone.	
SR/CR 3.2 (+ HDR 3.2)	Protection from malicious code	**AppArmor** enforcing (`aa-status`); signed APT repos only (`/etc/apt/sources.list*`, GPG keys); package integrity (`debsums -s`); optional ClamAV. No untrusted PPAs. **Ext. tools:** Lynis; `debsums`; OpenSCAP.	AppArmor enforcing; only signed packages; integrity verified.	HDR-specific.
SR/CR 3.3	Security Functionality Verification	Verify security functions operate correctly (self-test / post-change re-verification / compliance scan).	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 3.4 (+ HDR 3.14)	Software integrity & secure boot	**UEFI Secure Boot** (`mokutil --sb-state`); signed kernel/modules; file-integrity monitoring with **AIDE** (`aide --check`); GRUB password. **Ext. tools:** `mokutil --sb-state`; AIDE; OpenSCAP.	Secure Boot on; signed kernel/modules; file integrity monitored.	HDR-specific.
SR/CR 3.5	Input Validation	Assess per objective: Validate syntax and content of any process control input.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 3.6	Deterministic Output	**N/A.** Device does not drive process outputs; deterministic/fail-safe output is not applicable.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 3.7	Error Handling	Confirm errors are handled gracefully without leaking sensitive information or losing control.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 3.9	Protection of Audit Information	Confirm audit records are protected from unauthorized read/modify/delete (permissions + offload).	Met per SL-3 - verify on the product and capture evidence.	completeness
HDR 3.10	Support for updates	Patching via `apt` / **unattended-upgrades** (`/etc/apt/apt.conf.d/50unattended-upgrades`); confirm current (`apt list --upgradable`) and Livepatch (kernel) where used. **Ext. tools:** `apt list --upgradable`; Nessus (missing patches).	Signed updates applied promptly; auto-update for security patches.	HDR-specific.
HDR 3.11	Physical / removable media	Restrict USB/removable media (udev rules / `USBGuard`); GRUB + UEFI password; disable boot from USB. LUKS protects at rest. **Ext. tools:** Config review; physical inspection.	Removable media + boot controlled; disk encrypted.	HDR-specific.
HDR 3.12	Provisioning Supplier Roots of Trust (Host)	Assess the HDR-specific requirement per objective: Host device shall provision and protect product-supplier roots of trust used to validate firmware/identity.	Met per SL-3 - verify and capture evidence.	HDR completeness
HDR 3.13	Secure Boot (Host)	Assess the HDR-specific requirement per objective: Host device shall validate integrity of boot process.	Met per SL-3 - verify and capture evidence.	HDR completeness

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 4.1	Information confidentiality	**LUKS** full-disk encryption (`lsblk`, `cryptsetup status`); TLS in transit; correct permissions on sensitive files. **Ext. tools:** `cryptsetup status`; CIS scan.	Data-at-rest encrypted (LUKS) and in-transit (TLS).	
SR/CR 4.2	Information Persistence	Confirm sensitive data can be purged/sanitized on decommission or re-use.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 4.3	Use of cryptography	Strong SSH/TLS ciphers; system-wide crypto policy (where available) set to a strong profile; disable weak protocols. **Ext. tools:** ssh-audit; sslscan (host TLS services).	Modern strong crypto; weak ciphers/protocols disabled.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 5.1 / 5.2	Segmentation & boundary (host firewall)	**ufw**/nftables default-deny inbound with explicit allows: `ufw status verbose` / `nft list ruleset`; only required ports; host isolation where needed. **Ext. tools:** Nmap (open ports by segment); `ufw status`	Host firewall default-deny inbound; only required flows.	
SR/CR 5.3	General Purpose Person-to-Person Communication Restrictions	Assess per objective: Prevent general purpose messages from external users/systems.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 5.4	Application Partitioning	Assess per objective: Support partitioning of data, applications, services by criticality.	Met per SL-3 - verify on the product and capture evidence.	completeness

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 6.1 / 6.2	Audit accessibility & monitoring	Logs in `journalctl`/`/var/log` accessible; forward rsyslog/journald + auditd to the SIEM; host agent (Wazuh/osquery/EDR). **Ext. tools:** SIEM check; syslog listener (`nc -lu 514`).	Logs accessible and forwarded to SIEM; host monitoring active.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 7.1	Denial of Service Protection	Assess per objective: Operate in degraded mode during DoS events.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 7.2	Resource Management	Assess per objective: Limit resource use by security functions to prevent exhaustion.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 7.3 / 7.4	Backup & recovery	Automated backups of config/data + tested restore; verify job success and integrity (`sha256sum`). **Ext. tools:** Backup review; lab restore.	Recent verified backup; restore tested.	
SR/CR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Config settings baseline	Apply/verify the CIS/STIG baseline via OpenSCAP; document deviations. **Ext. tools:** `oscap xccdf eval --profile ds.xml`.	Host matches the CIS/STIG baseline; deviations documented.	
SR/CR 7.7	Least functionality	Remove unused packages/services: `systemctl list-unit-files --state=enabled`, `apt list --installed`; disable unneeded; close unused ports; no compilers/tools on production. **Ext. tools:** Lynis; Nmap (open ports); `ss -tlnp`	Only required packages/services/ports present.	
SR/CR 7.8	Component inventory	Capture OS/kernel/packages: `uname -a`, `lsb_release -a`, `dpkg -l`. **Ext. tools:** Inventory/EDR agent; ReadOnlyEnum.	Complete OS/kernel/package inventory captured.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
OpenSCAP (oscap) + CIS-CAT / STIG Viewer	Baseline compliance (all)	`oscap xccdf eval --profile --results r.xml ssg-ubuntu-ds.xml`; review in STIG Viewer; drives most pass/fail evidence.	Authorized scan account.
Lynis	Host hardening audit (most rows)	`lynis audit system`; review warnings/suggestions for auth, sudo, SSH, AppArmor, services.	Read-only audit.
ssh-audit	SSH config & crypto (1.1, 3.1, 4.3)	`ssh-audit` ; confirm strong KEX/cipher/MAC and hardened `sshd_config`.	Read-only.
sslscan / testssl.sh	TLS strength of host services (4.3)	`sslscan :`; confirm TLS1.2/1.3 + strong ciphers.	Read-only.
auditd (ausearch / auditctl)	Audit rules & events (2.8)	`auditctl -l`; `ausearch -m USER_LOGIN,USER_CMD` to confirm events are captured.	Read-only.
AIDE / debsums	File & package integrity (3.2, 3.4)	`aide --check`; `debsums -s` to detect modified files/packages.	Read-only.
Nmap	Port/service exposure & segmentation (1.13, 5.x, 7.7)	`nmap -sT -p- -T2` ; scan by segment; confirm only required ports open, no telnet/FTP.	Tune timing on production.
Nessus / OpenVAS	Known-CVE vulnerability scan (3.2, general)	Authenticated scan for missing patches/CVEs; cross-check USN advisories.	ISOLATED/authorized.
Hydra / fail2ban-client	Lockout behavior (1.11)	Authorized repeated SSH logins to confirm `pam_faillock`/fail2ban; `fail2ban-client status sshd`.	ISOLATED/authorized only.
ReadOnlyEnum	Host/network enumeration (7.8)	Enumerate services/ports/config read-only.	Read-only.

Controlled - Project Use · Independent Assurance Authority · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.